

부서주의 및 통보사항

일련번호 20정보기술 - 1
제목 정보시스템 계정관리 미흡
소관부서 ○○○○○○처, ○●▽●처
관계부서
내용

○○○○○○처 ○○○○부와 ▲▲▲▲▲부는 각각 정보시스템과 정보보안 장비 운영 및 유지보수 업무를 수행하면서 시스템 접속이 필요한 사용자 계정 및 접근 권한을 관리하고 있으며, ○●▽●처 ◇◇◇◇부는 정보보안 정책 수립·관리 업무를 담당하고 있다.

「정보보안기본지침」 제73조(계정관리)에 따라 개별사용자의 보직변경, 퇴직, 계약 종료 등 변동사항이 발생할 경우 신속히 사용자 계정을 삭제하거나 부여된 접근 권한을 회수해야 하고 사용자 계정 부여 및 관리의 적절성을 연 2회 이상 점검해야 한다.

따라서 전보 및 퇴직 등 인사변동이 있을 경우 자동적으로 불필요한 계정을 삭제하거나 권한을 회수하도록 하고 연 2회 사용자 계정 정기점검을 실시해야 함이 마땅하다.

그러나 ○○○○부¹⁾는 53개 Non-포포포 시스템에 대해 인사이동 후 자동적으로 계정에 부여된 권한을 회수하는 등의 권한 자동통제 기능을 구현하지 않았으며, 사용자 요청이 있을 때에만 비정기적으로 계정을 점검하였다.

1) 포포포 23개 시스템 및 Non-포포포 2개 시스템에 대해서는 권한 자동통제 기능 구현 및 연 2회 정기점검을 실시 중임

▲▲▲▲▲부는 정보보안장비에 등록된 사용자 계정에 대해 연 1회만 실시하거나 인사변동과 무관한 시점에 점검을 실시하는 등 계정관리가 미흡하였다.

또한, 「정보보안기본지침」에는 정기점검 시기 및 대상 시스템, 계정점검 결과에 대한 검토 주관부서 등의 구체적인 관리기준이 미비한 실정이다.

그 결과, ○○○○○부와 ▲▲▲▲▲부는 【표 1】과 같이 계정 관리를 미흡하게 처리하였다.

【표 1】 계정관리 미흡현황

구 분	대상 계정	대상 시스템
보직변경 후 권한 미 회수	369개	E&P시스템 등 22개
퇴직자 계정 미 삭제	114개	질의응답 시스템 등 8개
기타 불필요 계정	318개	ITSM 시스템 등 21개
합 계	총 801개	총 51개

조치할 사항

- ① 사용자 계정 정기점검을 소홀히 한 ○○○○○처 ○○○○○부와 ▲▲▲▲▲부에 주의 조치하시기 바랍니다. (부서주의)
- ② ○○○○○처장은 인사변동 시 자동적으로 사용자 계정이 삭제되거나 접근 권한이 회수되도록 시스템을 개선하시기 바랍니다. (통보)
- ③ ○●△▽●처장은 정기점검 시기, 주관부서 등 구체적인 관리기준을 「정보보안 기본지침」에 반영하시기 바랍니다. (통보)